

20-Race Conditions - Toy to The World

Introduction

The Story



La Mejor Compañía de Festivales (TBFC) lanzó su SleighToy de edición limitada, con solo diez piezas disponibles a medianoche. En cuestión de segundos, miles de personas se apresuraron a comprar uno, pero algo extraño ocurrió. Más de diez afortunados clientes recibieron correos electrónicos de confirmación indicando que sus pedidos se habían realizado correctamente. La confusión se extendió rápidamente. ¿Cómo pudo todo el mundo comprar el "último" juguete? Se llamó a McSkidy para que investigara.

Rápidamente se dio cuenta de que varios compradores compraban al mismo tiempo, burlando la falla de sincronización del sistema. Los traviesos Bandit Bunnies de Sir Carrotbane habían encontrado la manera de explotar este caos, inundando la caja con clics rápidos. Por la mañana, TBFC se enfrentó a compradores enfadados, falta de existencias y un misterio que reveló lo peligrosos que podían ser unos pocos milisegundos durante el ajetreo navideño.

Objetivos de aprendizaje

- Comprender qué son las condiciones de carrera y cómo pueden afectar a las aplicaciones web.
- Aprender a identificar y explotar las condiciones de carrera en las solicitudes web.
- Cómo las solicitudes concurrentes pueden manipular los valores de las existencias o las transacciones. Explore técnicas de mitigación simples para prevenir vulnerabilidades en condiciones de carrera.

Answer the questions below

I can successfully connect to the machine.

No answer needed

Race Condition

Una condición de carrera ocurre cuando dos o más acciones ocurren simultáneamente, y el resultado del sistema depende del orden en que terminan. En aplicaciones web, esto suele ocurrir cuando varios usuarios o solicitudes automatizadas acceden o modifican simultáneamente recursos compartidos, como el inventario o los saldos de las cuentas. Si no se realiza una sincronización adecuada, esto puede generar resultados inesperados, como transacciones duplicadas, artículos sobrevendidos o cambios de datos no autorizados.



Tipos de Condiciones de Carrera

Generalmente, los ataques de condición de carrera se pueden dividir en tres categorías:

- **Tiempo de Verificación a Tiempo de Uso (TOCTOU):** Una condición de carrera TOCTOU ocurre cuando un programa verifica algo primero y lo usa después, pero los datos cambian entretanto. Esto significa que lo que era cierto en el momento de la verificación podría dejar de serlo cuando se realiza la acción. Es como comprobar si un juguete está en stock y, para cuando haces clic en "Comprar", alguien más ya lo ha comprado. Por ejemplo, dos usuarios compran el mismo "último artículo" al mismo tiempo porque se verificó el stock antes de actualizarlo.
- **Recurso compartido:** Esto ocurre cuando varios usuarios o sistemas intentan modificar los mismos datos simultáneamente sin el control adecuado. Dado que ambas actualizaciones se realizan simultáneamente, el resultado final depende de cuál finalice último, lo que genera confusión. Imaginemos a dos cajeros actualizando la misma hoja de cálculo de inventario a la vez, y uno sobrescribe el trabajo del otro.
- **Violación de atomicidad:** Una operación atómica debería realizarse de una sola vez, ya sea completamente completa o no completada. Cuando partes de un proceso se ejecutan por separado, otra solicitud puede interferir y generar resultados inconsistentes. Es como pagar un artículo, pero antes de que el sistema lo confirme, alguien más cambia el precio. Por ejemplo, se registra un pago, pero la confirmación del pedido falla porque otra solicitud interrumpe el proceso.

Momento de actuar

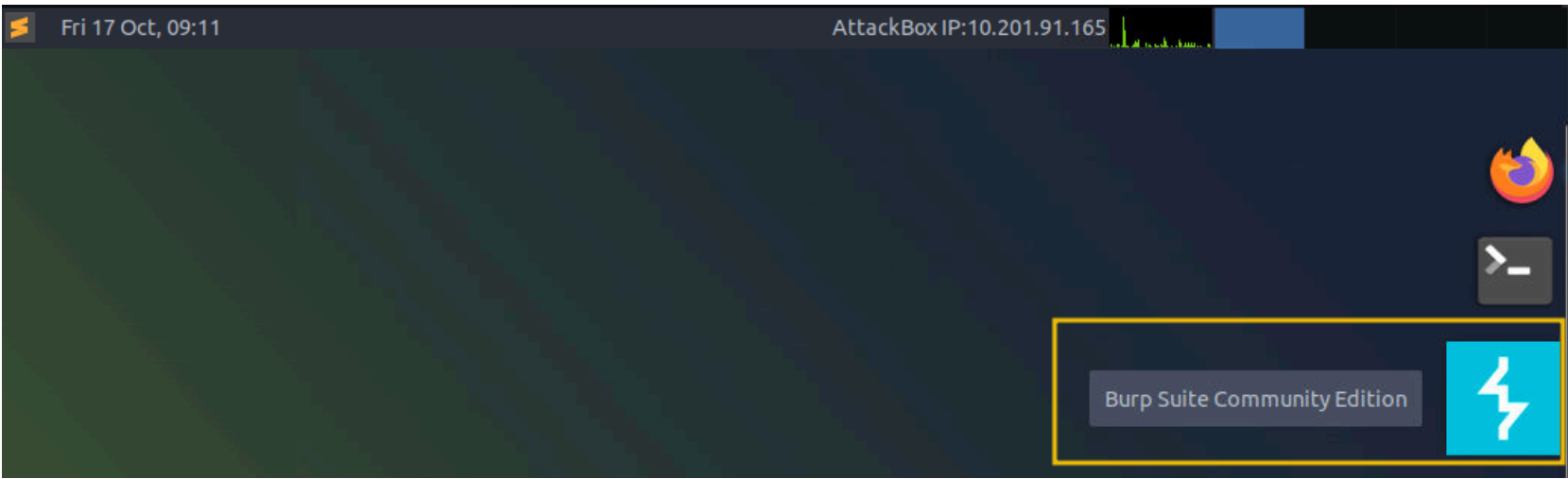
Ahora que comprendemos los conceptos básicos, tomemos el ejemplo de la aplicación de carrito de compras TBFC y exploremos la condición de carrera.

Configuración del entorno

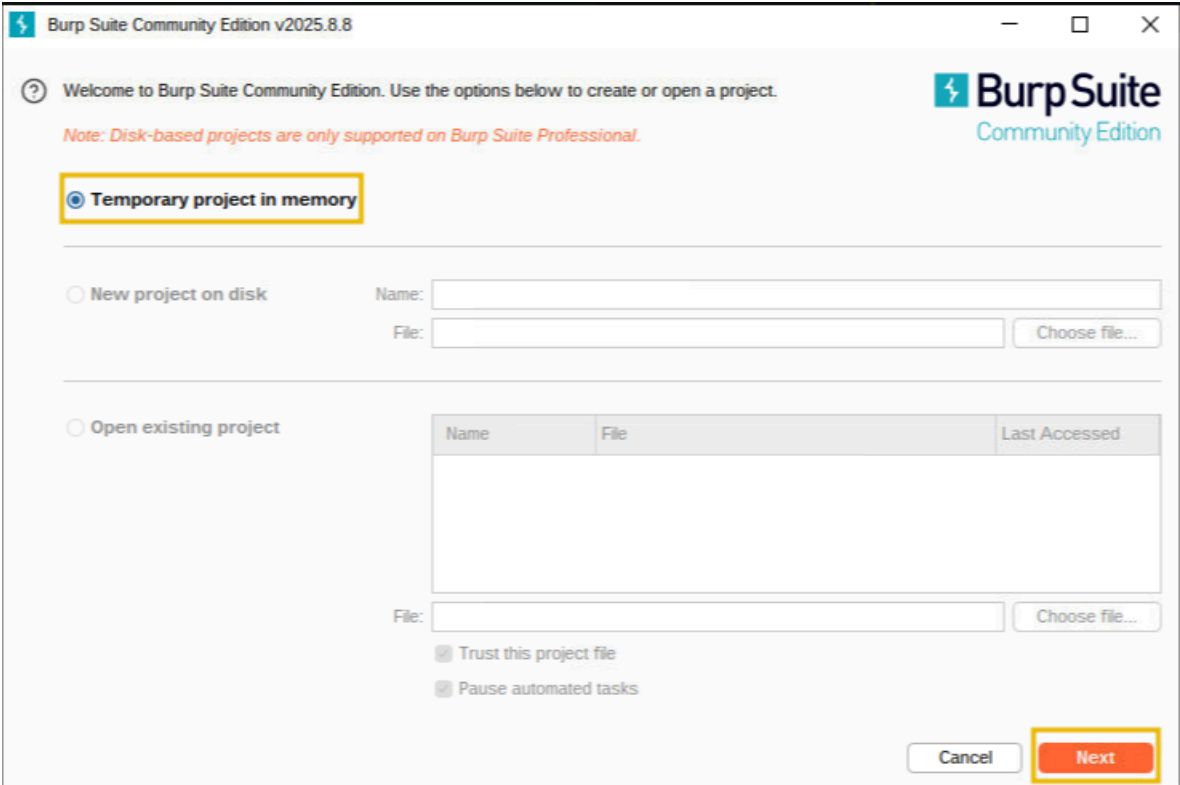
Primero, configuraremos Firefox para enrutar el tráfico a través de Burp Suite. En AttackBox, abra Firefox, haga clic en el icono de FoxyProxy (1) y seleccione el perfil Burp (2) para que todas las solicitudes del navegador se envíen a Burp, como se muestra a continuación:



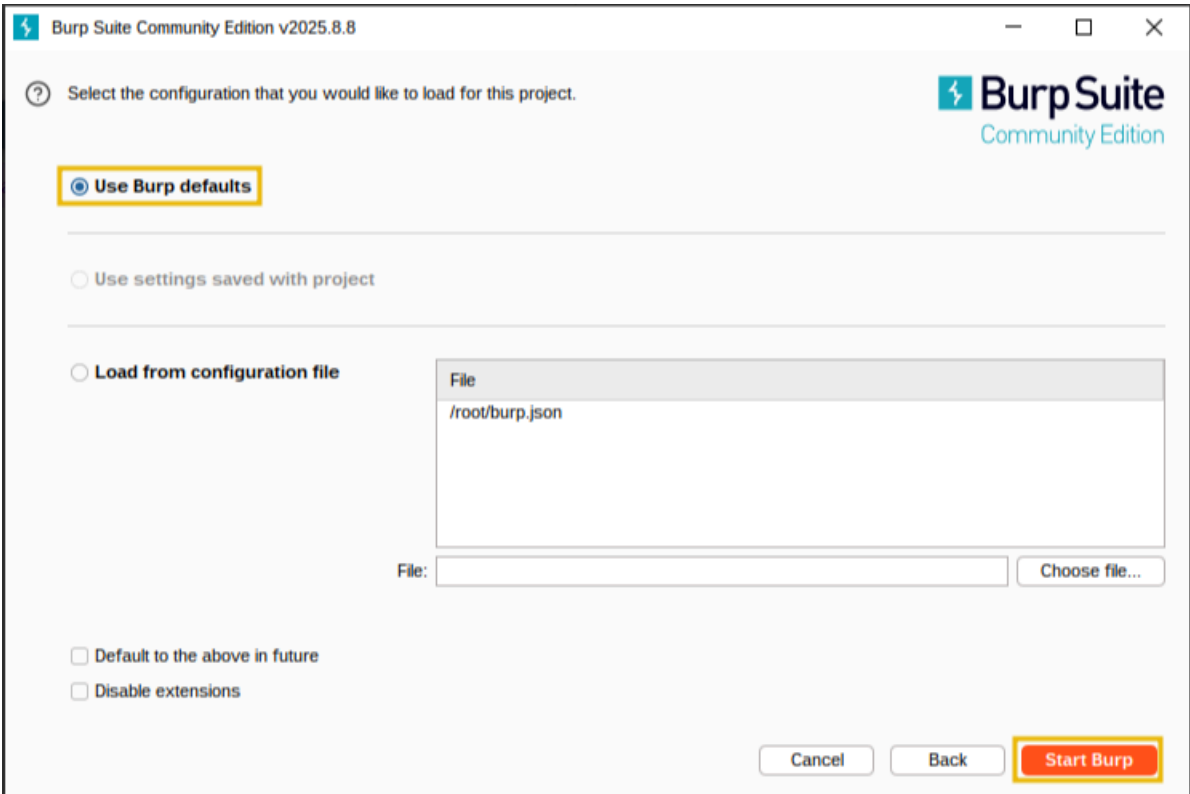
A continuación, haga clic en el icono de Burp Suite en el escritorio para iniciar la aplicación.



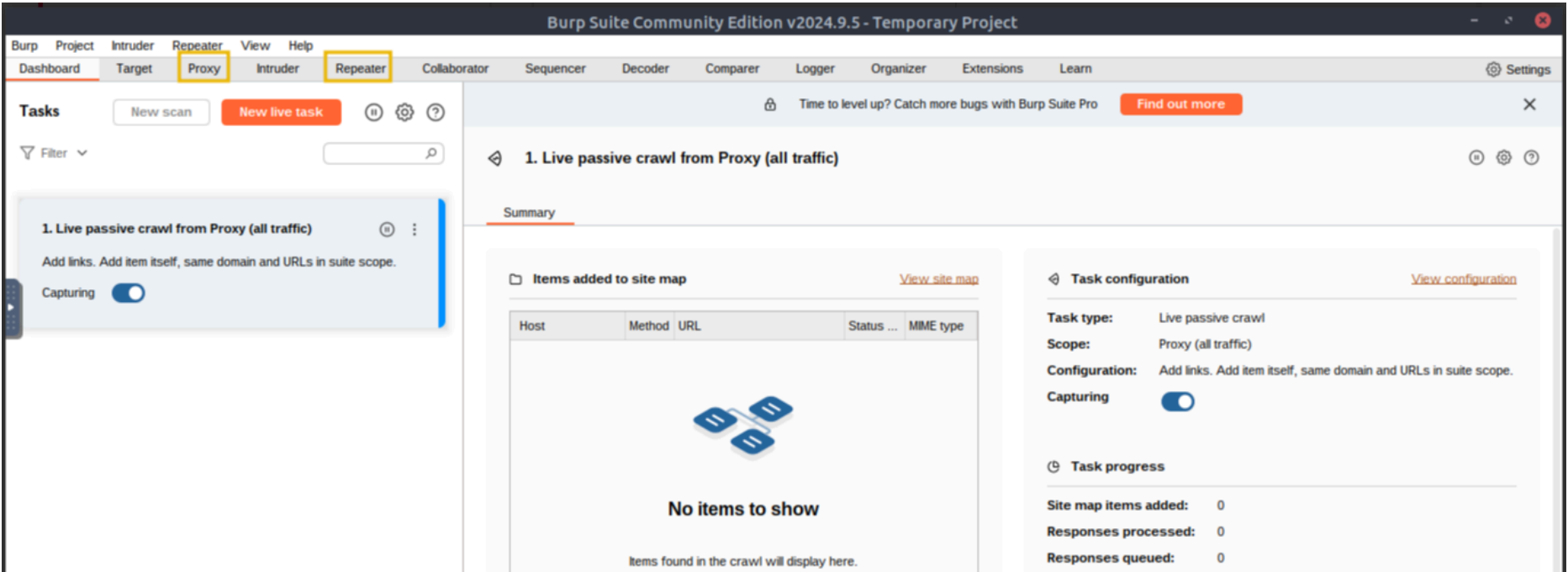
Verá una pantalla de introducción; seleccione Proyecto temporal en memoria y haga clic en Siguiente.



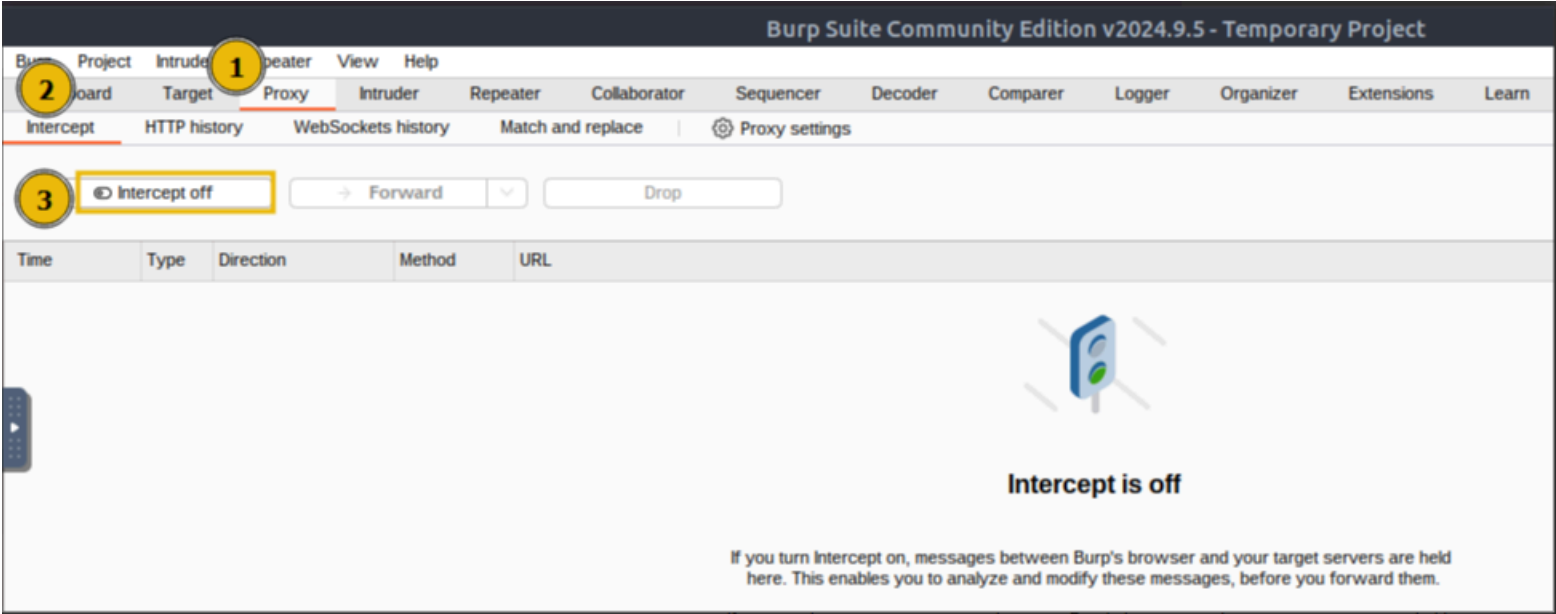
En la pantalla de configuración, haga clic en Iniciar Burp para iniciar la aplicación.



Una vez iniciada la aplicación verás la siguiente pantalla, donde utilizaremos la opción Proxy y Repetidor para explotar la condición de carrera.

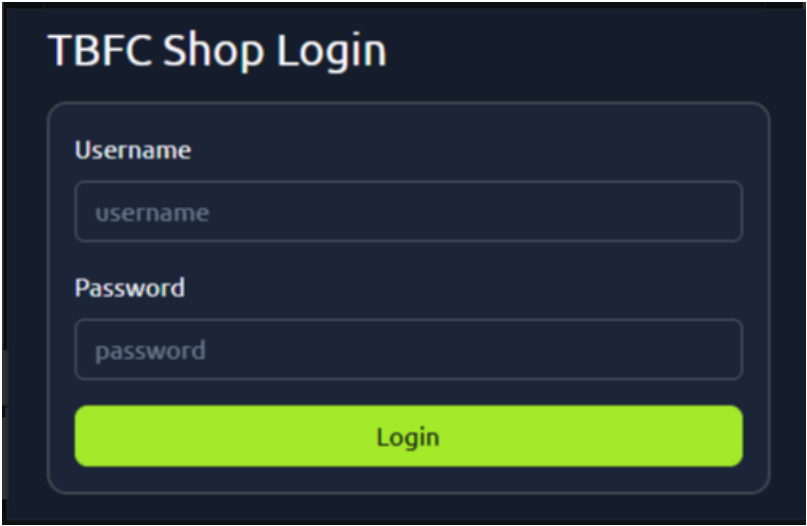


Antes de continuar, asegúrese de desactivar la función "Interceptar" en Burp Suite. Abra la pestaña "Proxy" y revise la subpestaña "Interceptar". Si el botón indica "Interceptar activado", haga clic en él para que cambie a "Interceptar desactivado". Este paso garantiza que Burp Suite ya no retenga las solicitudes de su navegador y las permita procesarse con normalidad.

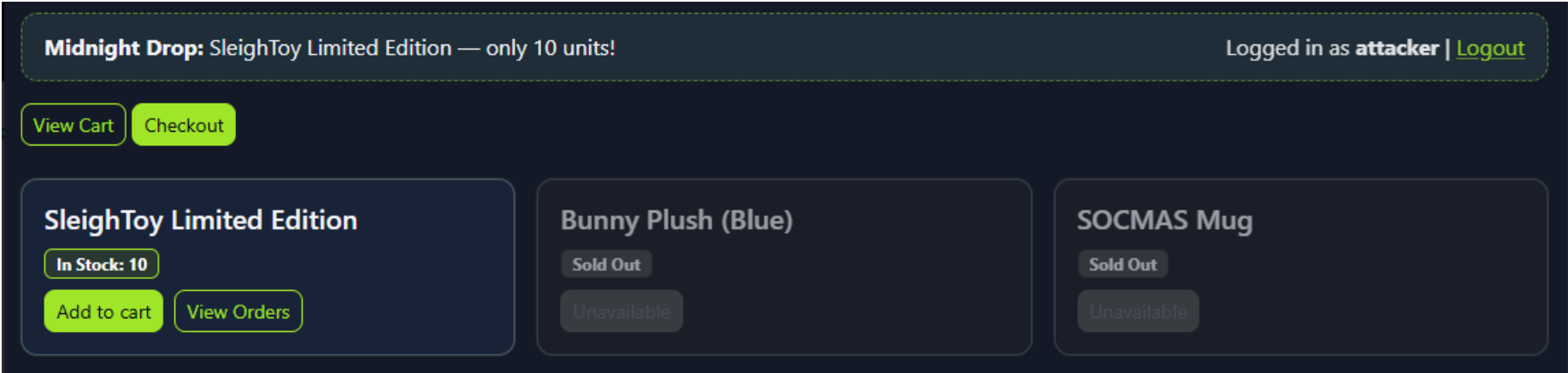


Realizar una solicitud legítima

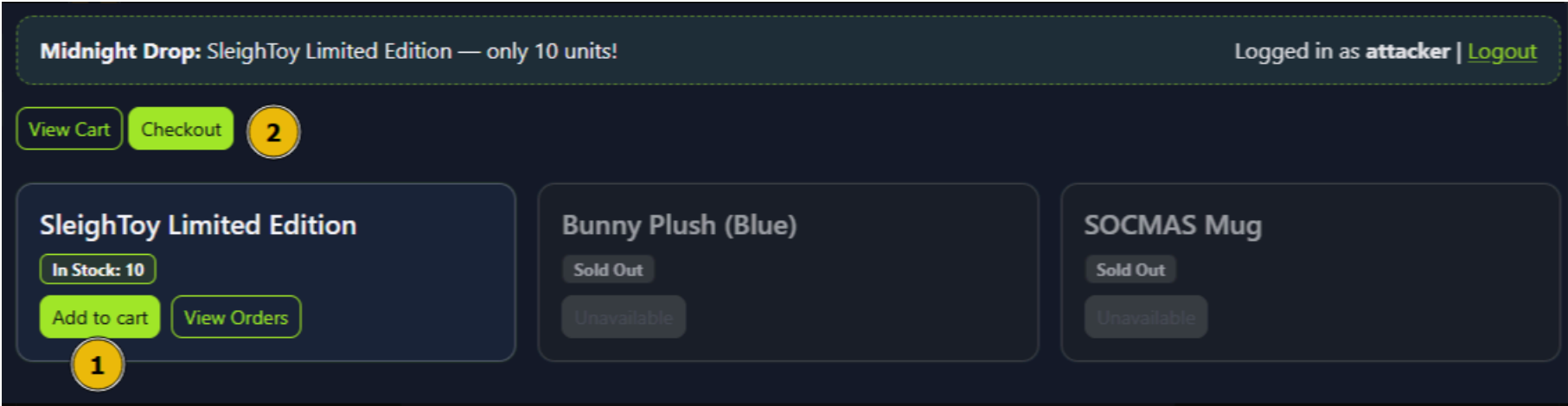
Ahora que el entorno está configurado, realice una solicitud normal. Abra Firefox, visite la aplicación web en http://MACHINE_IP y verá la siguiente página de inicio de sesión:



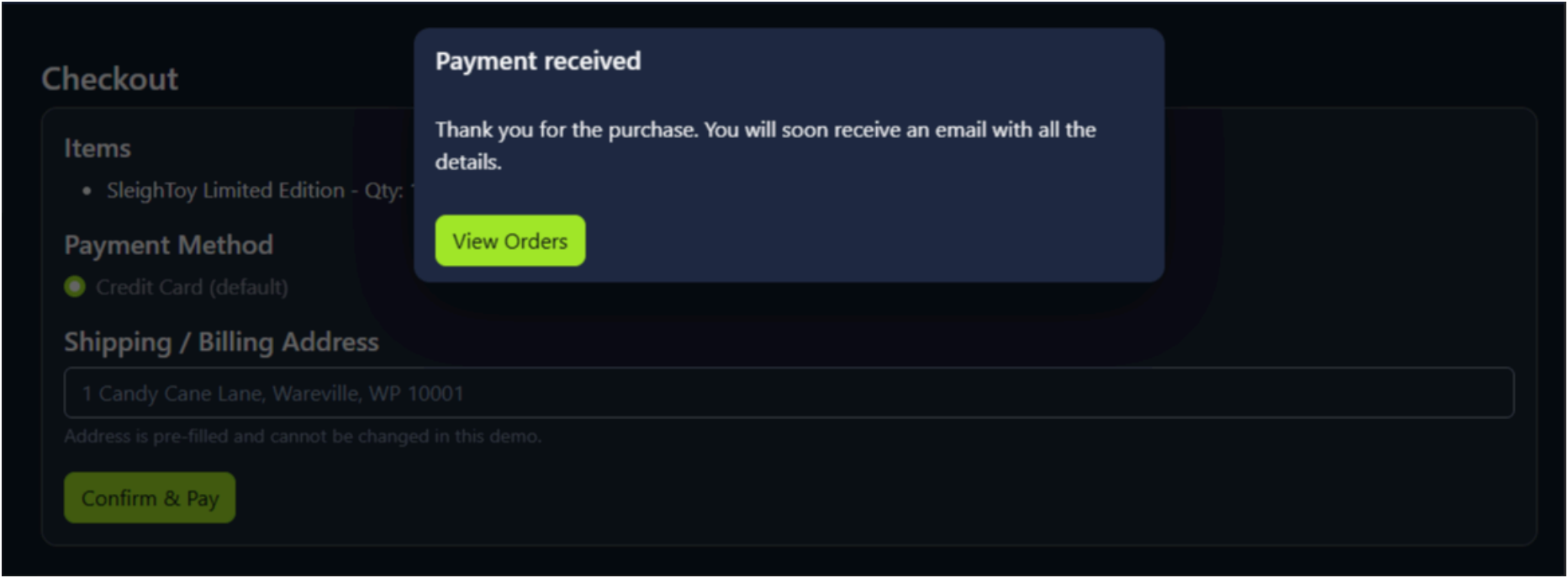
En el panel de inicio de sesión del sitio, introduce tus credenciales: usuario: attacker y contraseña: attacker@123. Tras iniciar sesión, accederás al panel principal, donde se muestra el SleighToy de edición limitada, con solo 10 unidades disponibles.



Para realizar una compra legítima, haga clic en Agregar al carrito para el SleighToy y luego haga clic en Pagar para ir a la página de pago.

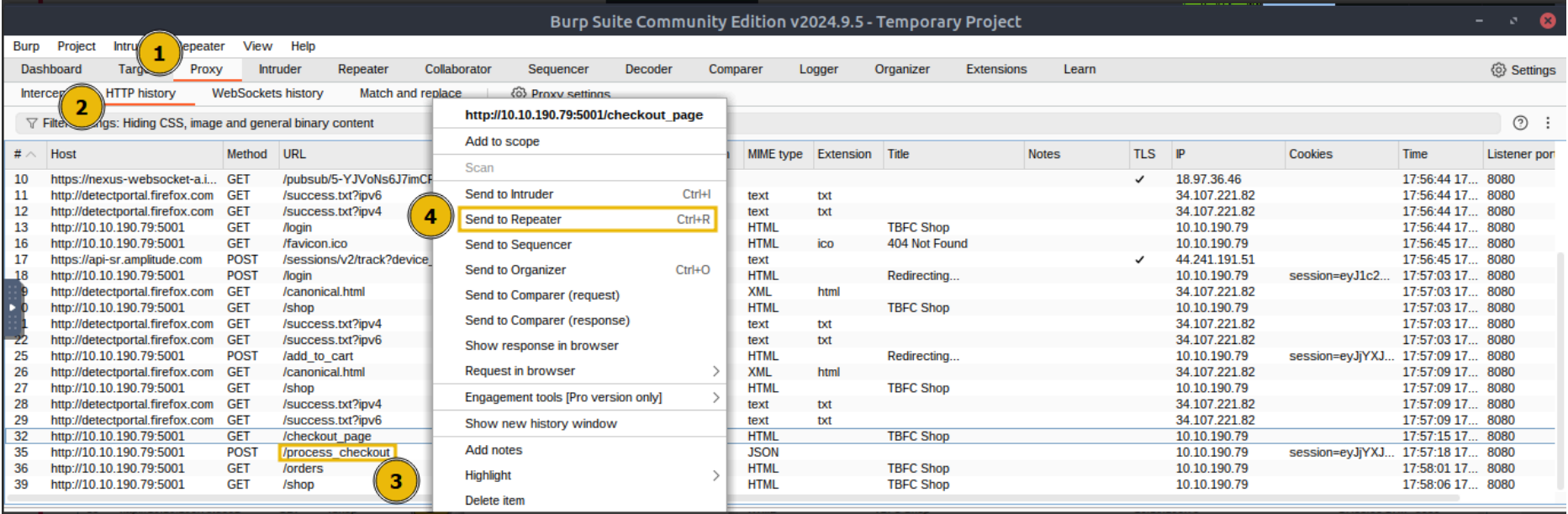


En la página de pago, haz clic en Confirmar y pagar para completar la compra. Verás un mensaje de confirmación de compra, como se muestra a continuación:

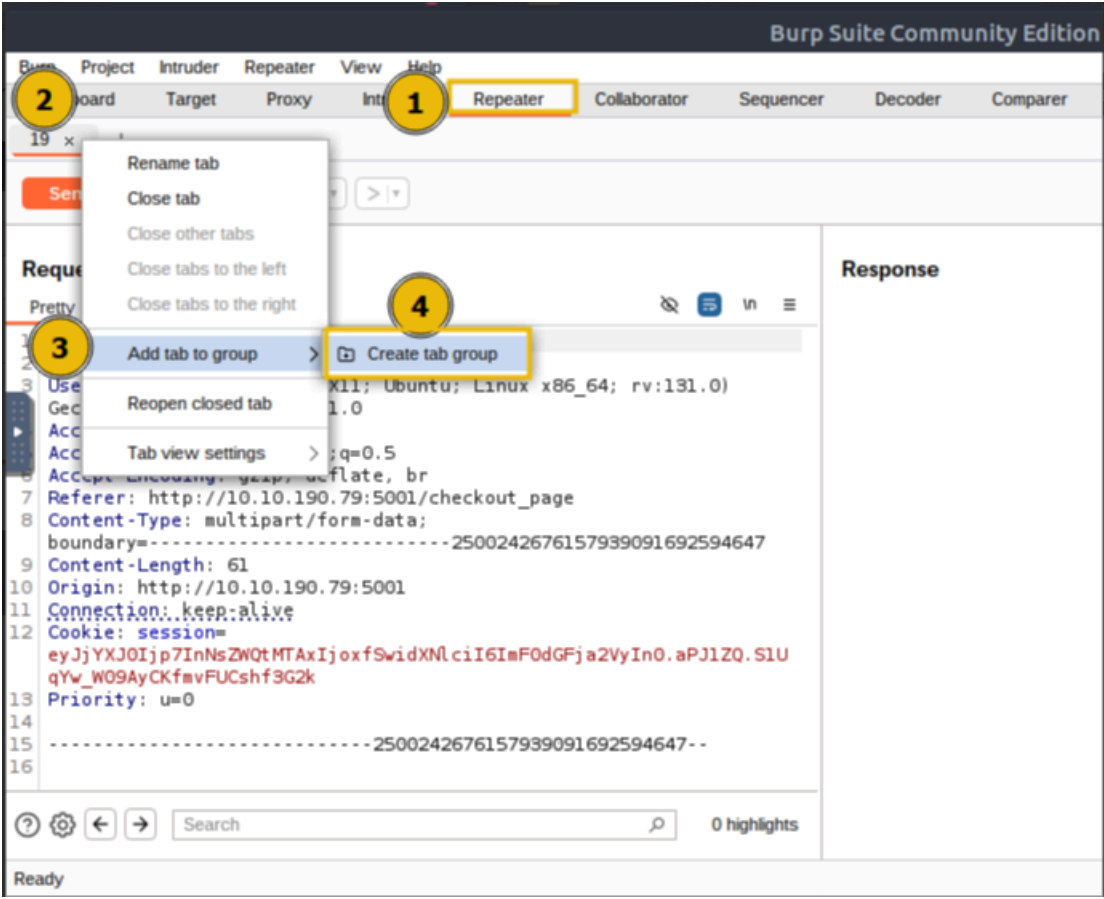


Aprovechamiento de la condición de carrera

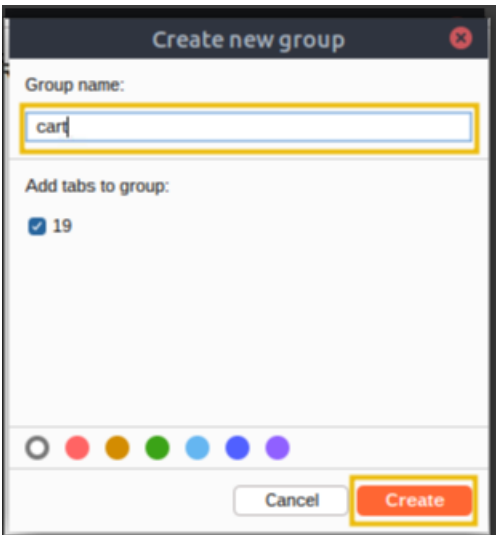
Ahora que hemos realizado una solicitud legítima, regrese a Burp Suite y haga clic en Proxy > Historial HTTP. Busque la solicitud POST al punto final /process_checkout creada por nuestra solicitud de pago legítima. Haga clic derecho en esa entrada y seleccione "Enviar a repetidor". Esto copiará la solicitud HTTP exacta (encabezados, cookies, cuerpo) en la herramienta Repetidor de Burp, como se muestra a continuación:



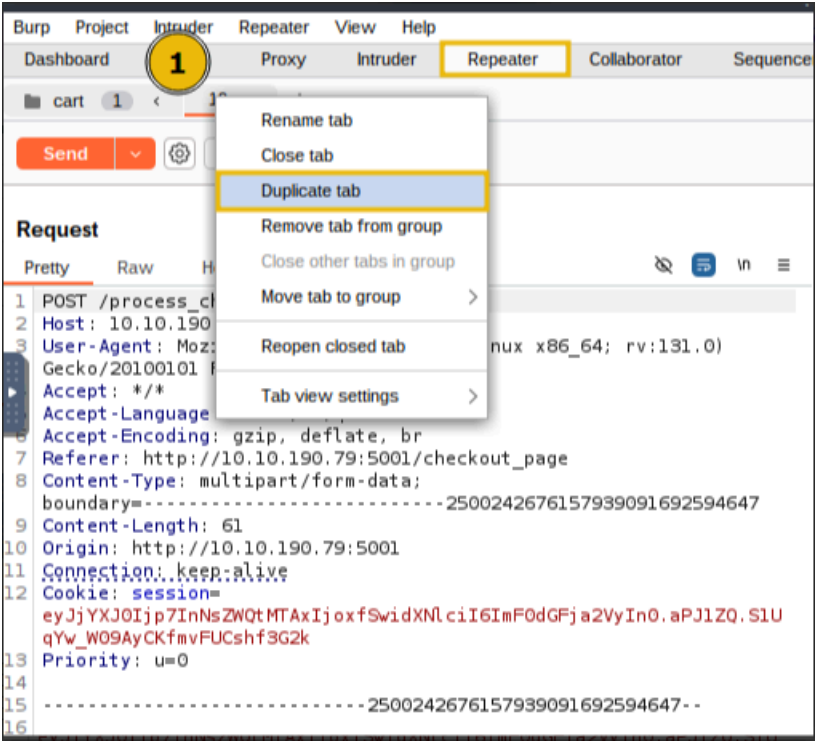
A continuación, cambie a la pestaña Repetidor y confirme que la solicitud aparece allí, haga clic derecho en la primera pestaña, seleccione Agregar pestaña al grupo y haga clic en Crear grupo de pestañas.



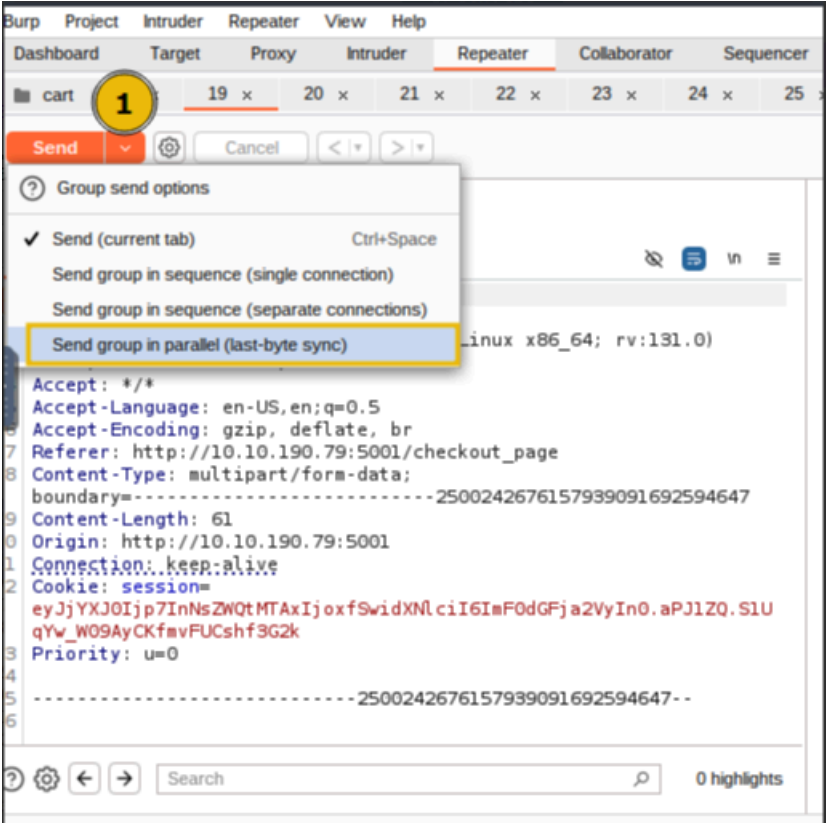
Ingrese un nombre para el grupo de pestañas, como carrito, y haga clic en Crear, lo que creará un grupo de pestañas llamado carrito.



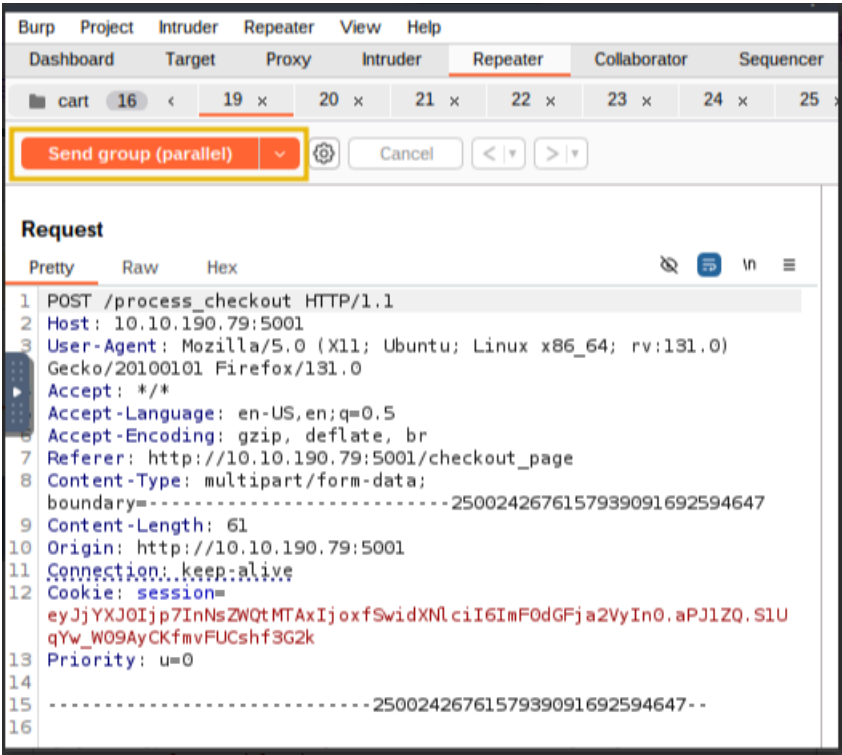
Luego, haz clic derecho en la pestaña de solicitud y selecciona Duplicar pestaña. Cuando se te solicite, introduce el número de copias que deseas (por ejemplo, 15). Ahora tendrás esa misma cantidad de pestañas de solicitud idénticas dentro del grupo del carrito.



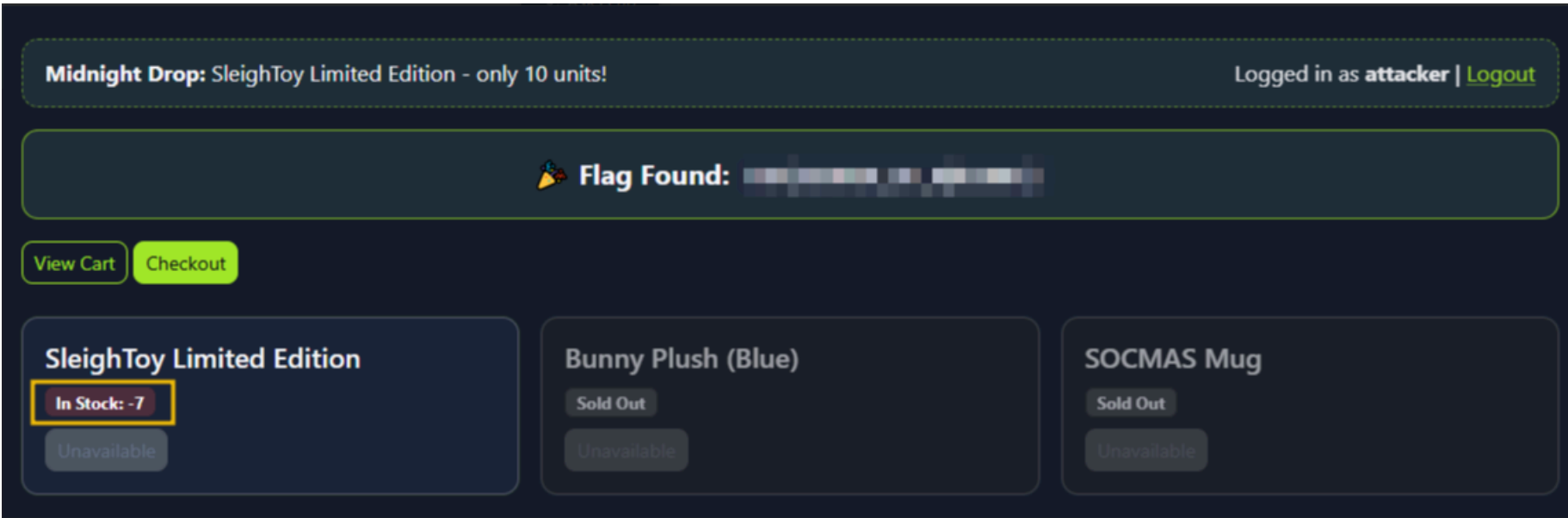
A continuación, utilice el menú desplegable Enviar de la barra de herramientas Repetidor y seleccione Enviar grupo en paralelo (sincronización de último byte), que lanza todas las copias a la vez y espera el byte final de cada respuesta, maximizando la superposición de tiempo para activar las condiciones de carrera.



Una vez hecho esto, haga clic en "Enviar grupo (en paralelo)". Esto enviará las 15 solicitudes al servidor simultáneamente. El servidor intentará procesarlas simultáneamente, lo que provocará el error de sincronización (debido al procesamiento de varias solicitudes a la vez).



Por último, visita la aplicación web y verás varios pedidos confirmados y el stock de SleightToy reducido (posiblemente se vuelva negativo).



Mitigación

El atacante inició sesión y realizó una compra normal del SleightToy de edición limitada. Con Burp Suite, capturó la solicitud de pago y la envió varias veces en paralelo. Debido a que la aplicación no gestionaba correctamente los pagos simultáneos, cada solicitud se completó correctamente antes de que se actualizara el stock. Esto le permitió comprar más juguetes de los disponibles, lo que provocó una condición de carrera y elevó el stock a valores negativos. A continuación, se presentan algunas medidas de mitigación para evitar la vulnerabilidad:

- Utilice transacciones atómicas de la base de datos para que la deducción de stock y la creación de pedidos se ejecuten como una sola operación consistente.
- Realice una validación final del stock justo antes de confirmar la transacción para evitar la sobreventa.
- Implemente claves de idempotencia para las solicitudes de pago a fin de garantizar que los duplicados no se procesen varias veces.
- Aplique controles de limitación de velocidad o concurrencia para bloquear intentos de pago rápidos y repetidos del mismo usuario o sesión.

Answer the questions below

What is the flag value once the stocks are negative for **SleightToy Limited Edition**?

Respuesta: THM{WINNER_OF_R@CE007}



Repeat the same steps as were done for ordering the SleightToy Limited Edition. What is the flag value once the stocks are negative for **Bunny Plush (Blue)**?

Respuesta: THM{WINNER_OF_Bunny_R@ce}

Burp Suite Community Edition v2024.9.5 - Temporary Project

BurpProjectIntruderRepeaterViewHelp

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearnSettings

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Filter settings: Hiding CSS, image and general binary content

#	^	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time
15		http://10.80.189.199	GET	/shop			200	2911	HTML		TBFC Shop			10.80.189.199		22:15:34
16		http://detectportal.firefox.com	GET	/success.txt?pv4		✓	200	216	text	txt				34.107.221.82		22:15:34
17		http://detectportal.firefox.com	GET	/success.txt?pv6		✓	200	216	text	txt				34.107.221.82		22:15:34
20		http://10.80.189.199	POST	/add_to_cart		✓	302	535	HTML		Redirecting...			10.80.189.199	session=eyJYXJ...	22:16:00
21		http://detectportal.firefox.com	GET	/canonical.html			200	298	XML	html				34.107.221.82		22:16:00
22		http://10.80.189.199	GET	/shop			200	2705	HTML		TBFC Shop			10.80.189.199		22:16:00
23		http://detectportal.firefox.com	GET	/success.txt?pv4		✓	200	216	text	txt				34.107.221.82		22:16:00
24		http://detectportal.firefox.com	GET	/success.txt?pv6		✓	200	216	text	txt				34.107.221.82		22:16:00
27		http://10.80.189.199	GET	/checkout_page			200	3895	HTML		TBFC Shop			10.80.189.199		22:16:13
30		http://10.80.189.199	POST	/process_checkout			200	616	JSON					10.80.189.199	session=eyJYXJ...	22:16:23
31		http://10.80.189.199	GET	/orders			200	5116	HTML		TBFC Shop			10.80.189.199		22:21:44
34		https://www.google.com	GET	/complete/search?client=firefox&c...	✓		200	1480	JSON				✓	209.85.202.103		22:22:20
35		http://10.80.189.199	GET	/shop			200	2750	HTML		TBFC Shop			10.80.189.199		22:22:22
38		http://10.80.189.199	POST	/add_to_cart		✓	302	536	HTML		Redirecting...			10.80.189.199	session=eyJYXJ...	22:25:38
39		http://detectportal.firefox.com	GET	/canonical.html			200	298	XML	html				34.107.221.82		22:25:38
40		http://10.80.189.199	GET	/shop			200	2543	HTML		TBFC Shop			10.80.189.199		22:25:38
41		http://detectportal.firefox.com	GET	/success.txt?pv6		✓	200	216	text	txt				34.107.221.82		22:25:38
42		http://detectportal.firefox.com	GET	/success.txt?pv4		✓	200	216	text	txt				34.107.221.82		22:25:38
45		http://10.80.189.199	GET	/checkout_page			200	3887	HTML		TBFC Shop			10.80.189.199		22:25:41
48		http://10.80.189.199	POST	/process_checkout			200	616	JSON					10.80.189.199	session=eyJYXJ...	22:25:52

Request

PrettyRawHex

1 POST /process_checkout HTTP/1.1

2 Host: 10.80.189.199

3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:131.0) Gecko/20100101 Firefox/131.0

4 Accept: */*

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Referer: http://10.80.189.199/checkout_page

8 Content-Type: multipart/form-data; boundary=-----350639407123022594973373573484

0 highlights

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

2 Server: Werkzeug/3.0.6 Python/3.8.10

3 Date: Sat, 20 Dec 2025 22:25:53 GMT

4 Content-Type: application/json

5 Content-Length: 322

6 Vary: Cookie

7 Set-Cookie: session=eyJYXJ0Ijp7fSwidXNlciI6ImF0dGFja2VyIn0.aUcicQ.vWW7j_4yMVtBaDhvZVIPMaDqBbQ; HttpOnly; Path=/

8 Connection: close

9

0 highlights

Inspector

Request attributes2

Request cookies1

Request headers12

Response headers7

http://10.80.189.199/process_checkout

Add to scope

Scan

Send to IntruderCtrl+I

Send to RepeaterCtrl+R

Send to Sequencer

BurpProjectIntruderRepeaterViewHelp

DashboardTargetProxyIntruderRepeater

17

Rename tab

Close tab

Close other tabs

Close tabs to the left

Close tabs to the right

Add tab to group>

Create tab group

Reopen closed tab

Tab view settings>

Create new group

Group name:

group 2

Add tabs to group:

☒ 17

CancelCreate

17 x +

Rename tab

Close tab

Duplicate tab

Remove tab from group

Close other tabs in group

Move tab to group>

Reopen closed tab

Tab view settings>

Duplicate tab

Duplicate 10 times

CancelDuplicate

group 2 11 < 17 x 18 x 19 x 20 x 21 x 22 x 23 x 24 x 25 x 26 x 27 x +

Send

Cancel

<

>

?

Group send options

✓

Send (current tab)

Ctrl+Space

Send group in sequence (single connection)

Send group in sequence (separate connections)

Send group in parallel (last-byte sync)

Accent

Send group (parallel)

18	5d474a4a-02bd-49eb-8326-110863f068d9	attacker	plush-001	1	5	4	2025-12-20T22:25:53.084356Z
19	bff73e9c-02fd-4ede-bc7a-54ff7e0e5bb6	attacker	plush-001	1	4	3	2025-12-20T22:29:14.077853Z
20	930cd3e7-8760-42bf-8885-16f323ab392e	attacker	plush-001	1	4	2	2025-12-20T22:29:14.079479Z
21	d1962327-5587-4de3-ae1d-b74a2764f5f0	attacker	plush-001	1	4	1	2025-12-20T22:29:14.081063Z
22	3e0e8264-95dd-4d67-838d-e5e3a79d8619	attacker	plush-001	1	4	0	2025-12-20T22:29:14.082164Z
23	f53ae7d5-cbe6-4823-8320-390518598388	attacker	plush-001	1	4	-1	2025-12-20T22:29:14.084205Z
24	32508e98-ddd0-41e2-b7a7-924731da96c3	attacker	plush-001	1	4	-2	2025-12-20T22:29:14.085350Z
25	4f39a657-7492-4eeb-bac8-20b4d5ed5935	attacker	plush-001	1	4	-3	2025-12-20T22:29:14.086662Z
26	1f81dc2e-0c0b-4d51-86b1-cb8ea9a7c0c0	attacker	plush-001	1	4	-4	2025-12-20T22:29:14.088168Z
27	ab60484b-8970-4cc4-82f3-84ad0e203eca	attacker	plush-001	1	4	-5	2025-12-20T22:29:14.090404Z
28	6b3905e4-ce29-4574-a674-23e82407ed88	attacker	plush-001	1	4	-6	2025-12-20T22:29:14.092714Z
29	8a1182c2-dea2-40ec-8edc-6197e08b27bf	attacker	plush-001	1	4	-7	2025-12-20T22:29:14.094383Z

Bunny Plush (Blue)

Over-sold: -7

Unavailable

🏆 Flag Found: THM{WINNER_OF_Bunny_R@ce}

Feel free to check out the [Race Conditions](#) room if you enjoyed this task.

Check